

Auditoria de Sistemas de Informação

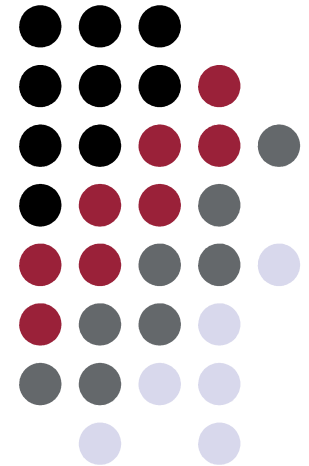


UFOP

Universidade Federal
de Ouro Preto

CEA463 – SEGURANÇA E AUDITORIA DE SISTEMAS

Profa. Msc. Helen de Cássia S. da Costa Lima
Universidade Federal de Ouro Preto



Metodologia COBIT



- Metodologia de auditoria para **avaliação de controles e cumprimento de processos de TI**
- Recomendado pela **ISACA** (Information Systems Audit and Control Association)
<http://www.isaca.org/COBIT/Pages/default.aspx>
- **Missão**
 - O CobiT (Control Objectives for Information and related Technolog) diz como pesquisar, desenvolver, publicar e promover um conjunto atualizado, autorizado e com foco internacional, de objetivos de controle geralmente aceitos e aplicáveis à tecnologia da informação para serem usados por gestores de TI, usuários e **auditores de sistemas**

Metodologia COBIT

Introdução



- O CobiT é uma referência mundial utilizada na avaliação de controles e cumprimento dos processos de TI, sendo amplamente adotado pelas empresas em todo o mundo
- Conjunto de diretrizes baseadas em auditoria de processos, práticas e controles de TI
- **Não** determina como os processos de TI devem ser estruturados, porém orienta sobre os controles que eles devem ter para que a TI cumpra seus objetivos em termos de **governança**



- **Governança de TI?**
 - Conjunto de responsabilidades e práticas que garantem que **os objetivos traçados pela TI, bons controles gerenciais e um efetivo monitoramento de performance** são mantidos na trilha e evitam situações inesperadas





- **Objetivos de negócios** requerem informações:
 - **Informações** devem atender aos critérios de **qualidade, segurança e confiabilidade**
- Informações são produzidas por recursos de **TI**:
 - Dados, aplicações, infraestrutura e pessoas
- Recursos de TI são gerenciados por **processos**:
 - Definição de responsabilidades e metas
- Processos devem ser **controlados**:
 - Objetivos de controle, indicadores de desempenho e indicadores de resultados

Metodologia COBIT

Características Gerais



- **Foco no negócio:**
 - Alinhamento das metas de TI a metas de negócio
- **Orientado a processos:**
 - Organização das atividades de TI em um modelo de processos aplicável de forma geral
 - Identificação de responsabilidades pelos processos nas áreas de negócio e TI
- **Baseado em controles:**
 - Definição dos objetivos de controle a serem considerados pela gerência
- **Dirigido por métricas:**
 - Uso de indicadores e modelos de maturidade

Metodologia COBIT

Aplicação do COBIT



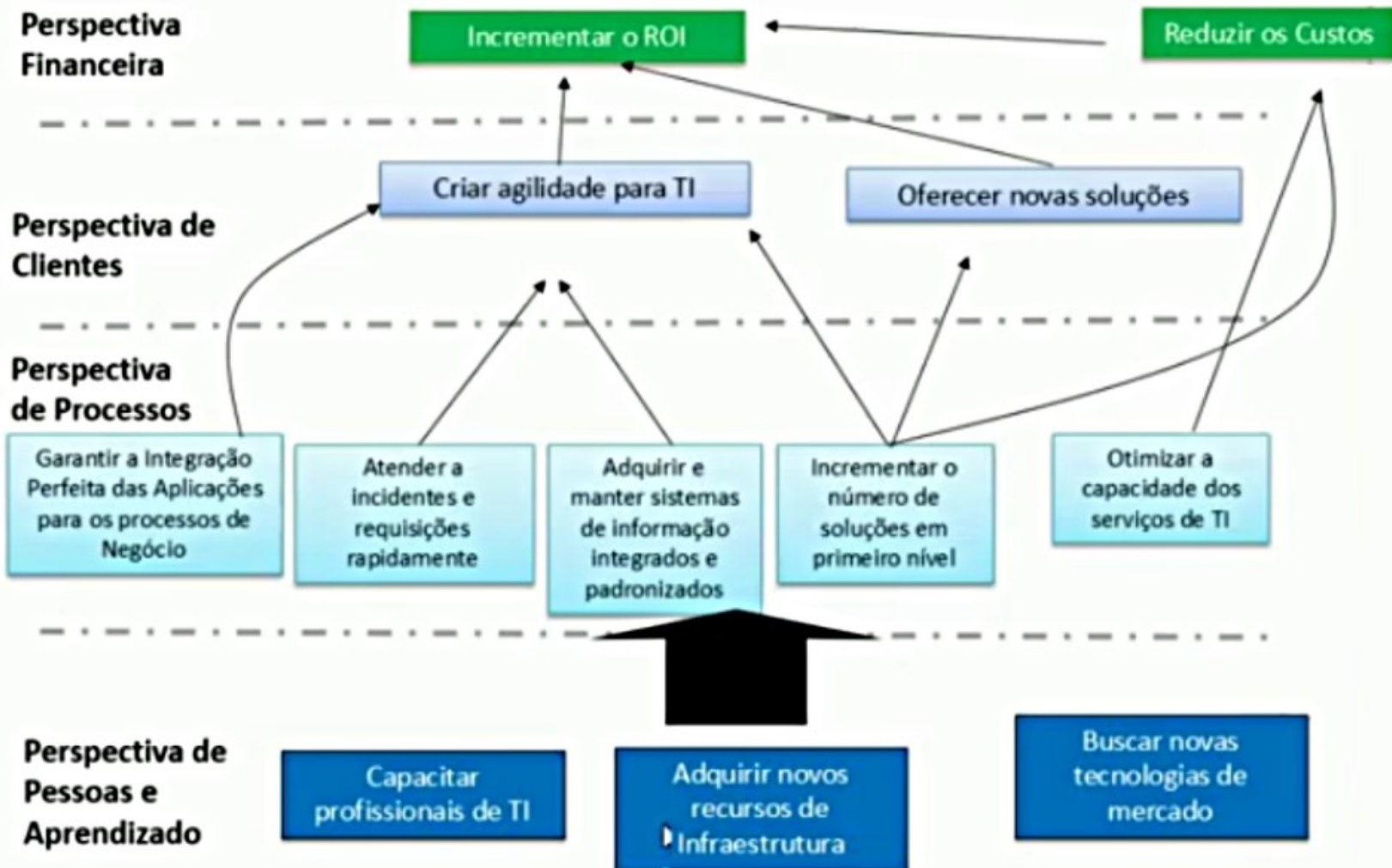
- O CobiT foi projetado para utilização por três distintos públicos:
 - **Administradores:** como instrumento de avaliação entre risco e investimento e controle do ambiente de TI
 - **Usuários:** certificação de segurança dos serviços fornecidos por TI (internos ou externos)
 - **Auditores de Sistemas:** permitir uma avaliação padronizada para fundamentar a sua opinião sobre o TI da organização e permitir apresentar recomendações à administração sobre melhoria dos controles internos

Metodologia COBIT

Aplicação do COBIT



✓ Mapa Estratégico de TI





- O CobiT está estruturado em **34 processos de controle**, um para cada **objetivo de TI**, e agrupados em **4 domínios**:
 - Planejamento e Organização (**P**lan and **O**rganise)
 - Adquirir e Implementar (**A**cquire and **I**mplement)
 - Entregar e Suportar (**D**eliver and **S**upport)
 - Monitorar e Avaliar (**M**onitor and **E**valuate)
- Os **34 processos** estão alicerçados em **318 ações/atividades** de controle que devem ser implementadas



Planejar e Organizar

- **Objetivos:**

- Formular estratégias e táticas
- Identificar como TI pode melhor contribuir para obter os objetivos de negócio
- Planejar, comunicar e gerenciar a realização da visão estratégica
- Implementação organizacional e tecnológica da Infraestrutura

- **Escopo:**

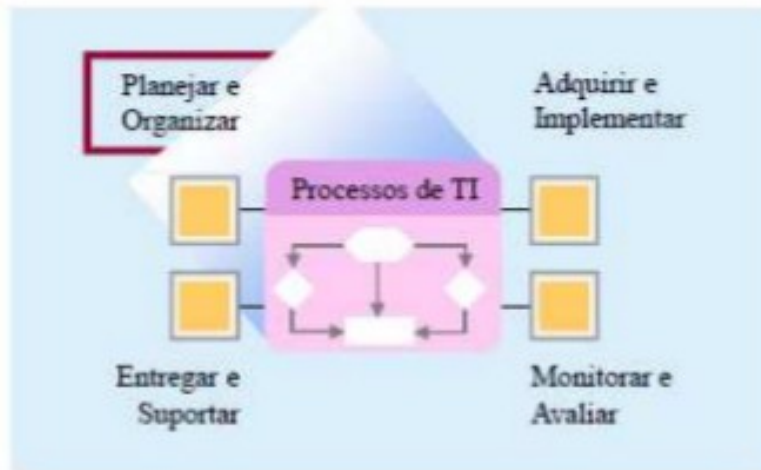
- Estão TI e Negócio estrategicamente alinhados?
- Está a organização obtendo uso ótimo de seus recursos?
- Qualquer pessoa na organização entende os objetivos de TI?
- Os riscos de TI são entendidos e adequadamente gerenciados?
- A qualidade dos sistemas de TI são apropriadas para as necessidades do negócio?

Metodologia COBIT

Estrutura - Domínios



Planejar e Organizar

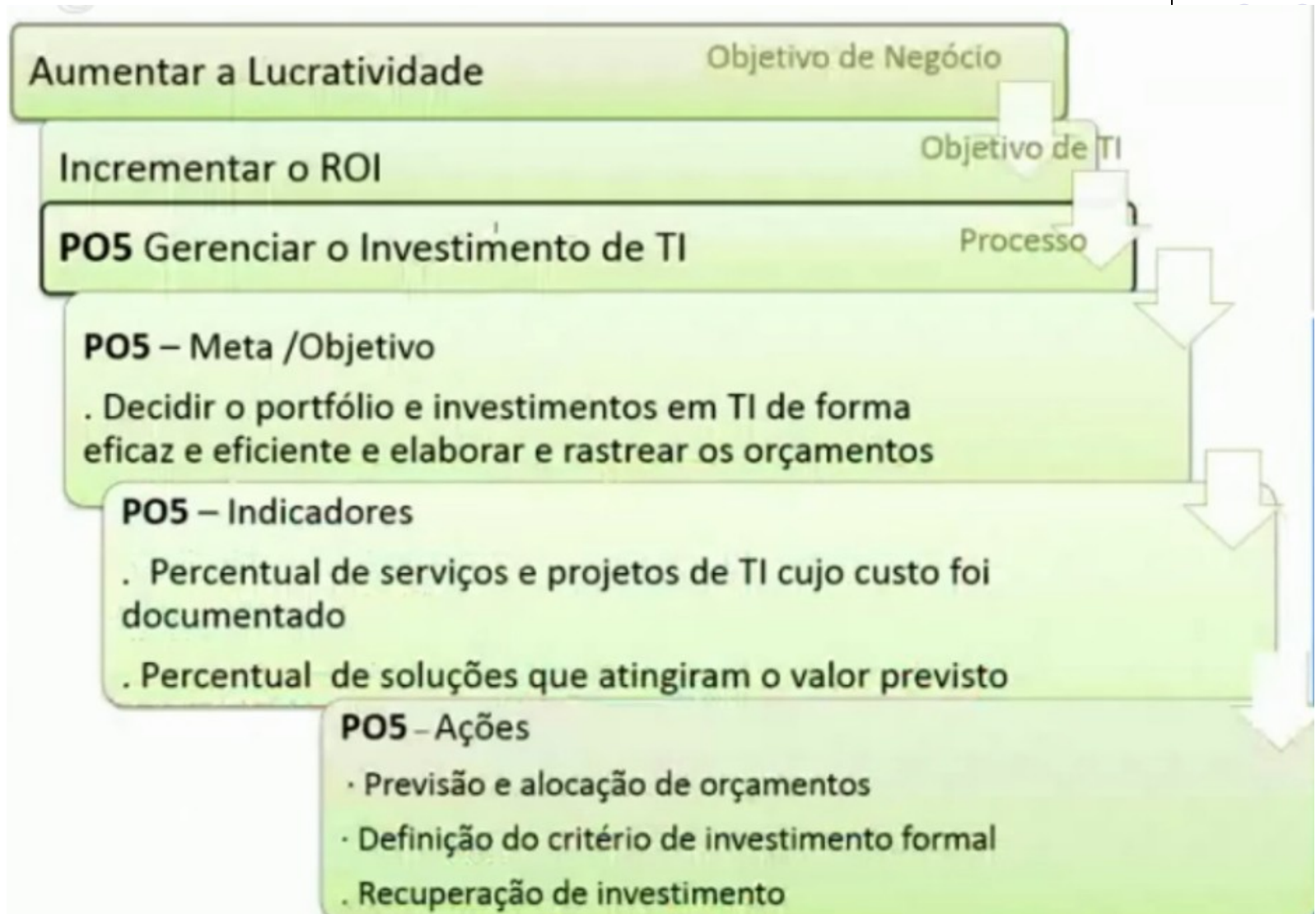


Planejar e Organizar

- PO1 Definir um plano estratégico de TI.
- PO2 Definir a arquitetura da Informação.
- PO3 Determinar a direção tecnológica.
- PO4 Definir os processos, organização e relacionamento de TI.
- PO5 Gerenciar os investimentos em TI.
- PO6 Auxiliar no Gerenciamento da Comunicação e do Direcionamento.
- PO7 Gerenciar os Recursos Humanos de TI.
- PO8 Gerenciar a Qualidade.
- PO9 Avaliar e controlar os Riscos de TI.
- PO10 Gerenciar Projetos.



Planejar e Organizar





Adquirir e Implementar

- **Objetivos:**

- Identificar, desenvolver ou adquirir, implementar e integrar soluções de TI
- Mudanças e manutenção dos sistemas existentes

- **Escopo:**

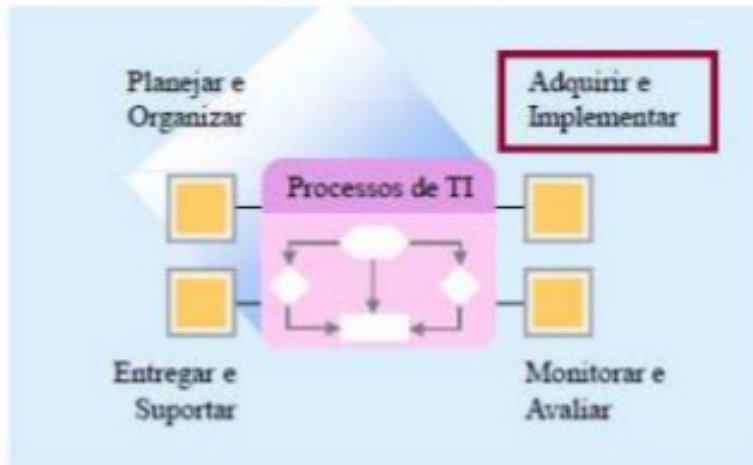
- Estão os novos projetos aptos a entregar soluções que reúnem as necessidades de negócio?
- Estão os novos projetos aptos a serem entregues dentro dos custos e prazos definidos?
- Os novos sistemas trabalharão adequadamente quando implementados?
- As mudanças serão feitas sem afetar as operações atuais do negocio?

Metodologia COBIT

Estrutura - Domínios



Adquirir e Implementar



Adquirir e Implementar

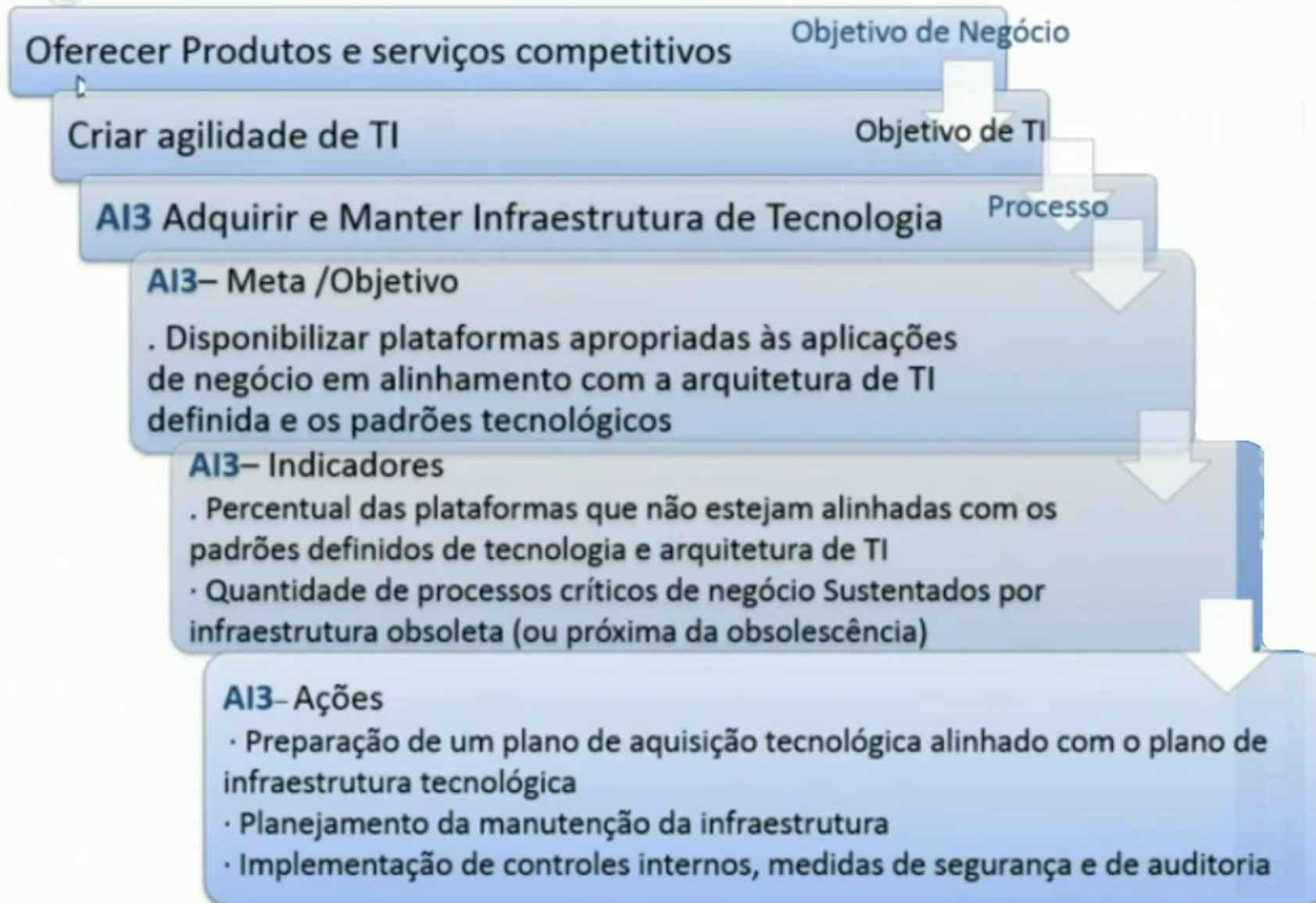
- AI1 Identificar soluções automáticas.
- AI2 Adquirir e manter software aplicativo.
- AI3 Adquirir e manter tecnologicamente a Infraestrutura.
- AI4 Habilitar Operação e Uso.
- AI5 Procurar recursos de TI.
- AI6 Gerenciar mudanças.
- AI7 Instalar e certificar soluções e mudanças

Metodologia COBIT

Estrutura - Domínios



Adquirir e Implementar





Entregar e Suportar

- **Objetivos:**

- A atual entrega dos serviços requeridos, incluindo o serviço de entrega
- **Gerenciamento da segurança, continuidade, dados e facilidades operacionais**
- Serviço de suporte a usuários estruturado

- **Escopo:**

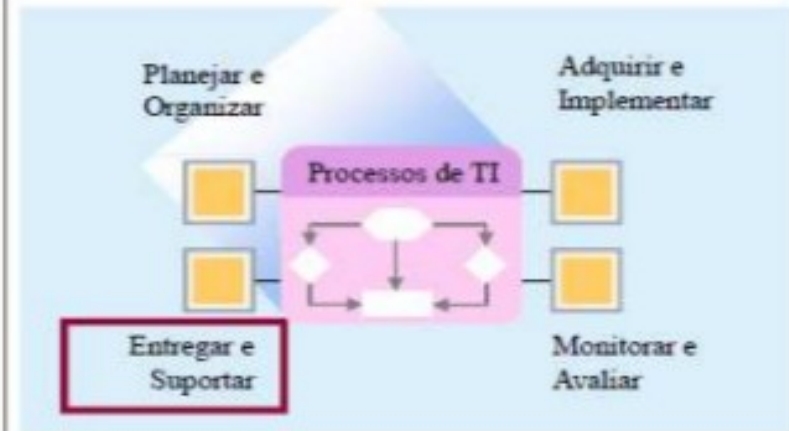
- Estão os serviços de TI alinhados com as prioridades de negócio?
- Estão os custos otimizados?
- Está a força de trabalho apta a usar os sistemas de TI de forma produtiva e com segurança?
- São adequadas a **confidencialidade, integridade e disponibilidade** das informações?



Entregar e Suportar

Entregar e Suportar

- DS1 Definir e gerenciar Níveis de Serviços.
- DS2 Gerenciar os Prestadores de Serviços.
- DS3 Gerenciar Disponibilidade e Capacidade.
- DS4 Garantir a Continuidade dos Serviços.
- DS5 Garantir a Segurança dos Sistemas.
- DS6 Identificar e alocar os Custos.
- DS7 Educar e treinar Usuários.
- DS8 Gerenciar a Central de Serviços e Incidentes.
- DS9 Gerenciar a Configuração.
- DS10 Gerenciar Problemas.
- DS11 Gerenciar Dados.
- DS12 Gerenciar o Ambiente Físico.
- DS13 Gerenciar Operações.





Monitorar e Avaliar

- **Objetivos:**

- Gerenciamento de performance
- Monitoramento de controles internos

- **Escopo:**

- A performance de TI é mensurada para detectar problemas antes que eles aconteçam?
- Gerenciamento garante que controle internos são efetivos e eficazes?
- Pode a disponibilidade de TI ser combinada aos objetivos de negócios?
- São riscos, controle, conformidade e performance medidos e reportados?



Monitorar e Avaliar

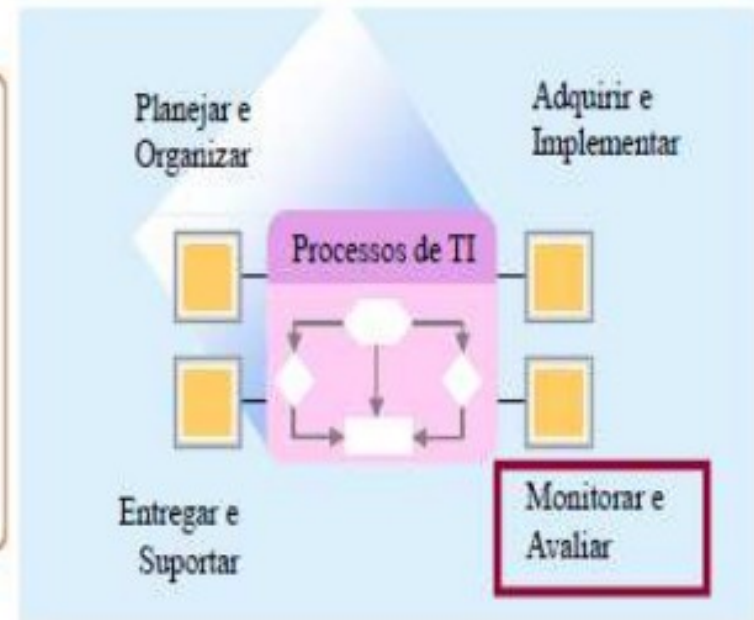
Monitorar e Avaliar

ME1 Monitorar e avaliar a Performance de TI.

ME2 Monitorar e avaliar Controles Internos.

ME3 Garantir conformidade com exigências externas.

ME4 Prover Governança de TI.



Metodologia COBIT

Modelo de Maturidade



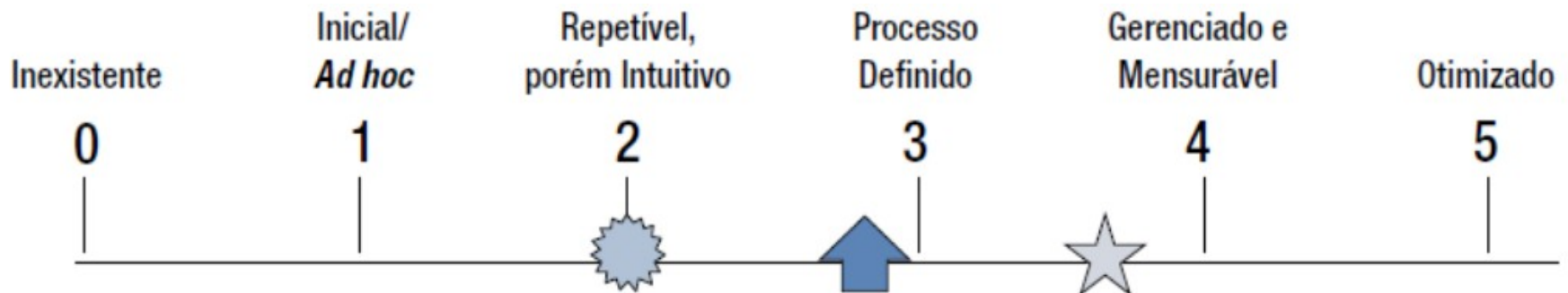
- Modelo que estabelece **níveis de maturidade para cada processo de TI** para uma organização ser medida e avaliada
- Os níveis são:
 - **Nível 0 (Inexistente)**. A empresa não reconhece a existência de um processo a ser gerenciado
 - **Nível 1 (Inicial)**. Processos são esporádicos e desorganizados e o gerenciamento é realizado caso a caso
 - **Nível 2 (Repetível)**. Os processos são estruturados e procedimentos similares são seguidos por diferentes indivíduos para a mesma tarefa



- Os níveis são:
 - **Nível 3 (Definido).** Os processos são padronizados, documentados e comunicados
 - **Nível 4 (Gerenciado e Mensurável).** Processos são monitorados e medidos quanto à conformidade com os procedimentos, e ações são tomadas quando os resultados não são efetivos
 - **Nível 5 (Otimizado).** Melhores práticas são adotadas e os processos automatizados. Há preocupação com melhoria contínua

Metodologia COBIT

Modelo de Maturidade



LEGENDAS PARA OS SÍMBOLOS UTILIZADOS

-  Estágio atual da empresa
-  Média do mercado
-  Meta da empresa

LEGENDA UTILIZADA PARA MEDIÇÃO

- 0 - Gerenciamento de processos não aplicado.
- 1 - Processos são *ad hoc* e desorganizados.
- 2 - Processos seguem um caminho padrão.
- 3 - Processos são documentados e comunicados.
- 4 - Processos são monitorados e medidos.
- 5 - Boas práticas são seguidas e automatizadas.



- O COBIT possibilita aos **auditores confrontar os processos de TI específicos com os objetivos da administração**, para determinar onde os controles são suficientes ou onde podem ser aperfeiçoados, apresentando as recomendações para a sua melhoria
- As diretrizes de auditoria estão estruturadas para uma avaliação adequada dos controles internos da organização, a identificação das áreas de risco e o envolvimento da área de TI com os negócios da organização

Processo de Auditoria



- O processo da auditoria está dividido em quatro etapas:
 - 1) Análise do ambiente empresarial e qualidade da administração
 - 2) Avaliação dos controles internos, abrangendo a área de TI
 - 3) Testes de Observância /conformidade (Pré)
 - 4) Testes Substantivos (Pós)

Processo de Auditoria

Requisitos para auditoria de processos



- 1) Definir o **escopo** da auditoria
- 2) Enfoque com o processo do **negócio**
- 3) **Plataformas, sistemas e seus relacionamentos** com o suporte ao processo
- 4) **Estrutura organizacional**, funções e divisão de responsabilidades
- 5) **Identificar requisitos de informação** relevantes para o processo do negócio

Processo de Auditoria

Requisitos para auditoria de processos



- 6) **Identificar riscos** inerentes de TI e um nível de controle abrangente
- 7) **Mudanças recentes e incidentes** no negócio e ambiente e TI
- 8) **Resultados** de auditorias, auto-avaliações e certificações
- 9) **Controles de monitoramento** adotados pela administração
- 10) **Selecionar processos** e plataformas a serem auditadas



Modelo de Auditoria Interna usando COBIT – Estudo de caso do BACEN





- Contexto do Bacen
- Evolução da Auditoria Interna de TI no Bacen
- Uso do Cobit no Processo de Auditoria de TI
- Plano Anual de Atividades da Auditoria Interna
- Processo de Auditoria Interna de TI
 - Planejamento; Execução; e Relatório
- Conclusões



Contexto do Bacen

- Instituição Federal vinculada ao Ministério da Fazenda
- Tem por finalidade:
 - a formulação, a execução, o acompanhamento e o controle das **políticas monetária, cambial, de crédito e de relações financeiras com o exterior**
 - a organização, a disciplina e a fiscalização do **Sistema Financeiro Nacional**
 - a gestão do **Sistema de Pagamentos Brasileiro** e dos **serviços do meio circulante**



Evolução da Auditoria Interna de TI no Bacen

- Auditoria Interna (IIA – Instituto de Auditores Internos do Brasil)
 - A auditoria interna é uma atividade independente e objetiva que **presta serviços de avaliação** e de **consultoria** com o objetivo de **adicionar valor e de melhorar as operações de uma organização**
 - A auditoria auxilia a organização a alcançar seus objetivos por meio de uma **abordagem sistemática** e disciplinada para a avaliação e a melhoria da eficácia dos **processos** de gerenciamento de **risco**, do **controle** e da **governança corporativa**



Evolução da Auditoria Interna de TI no Bacen

1998 - 2001 – Auditorias focadas no operacional da área de TI;

2002 - 2003 – Os sistemas de informação passam a ser os objetos de auditoria;

2004 - 2005 – A gestão de TI ganha destaque, mas ainda foca principalmente os aspectos operacionais;

2006 - 2008 – Os objetos de auditoria são definidos com base nas áreas de conhecimento de TI;

2009 - 2011 – Auditoria baseada em processos, conforme orientam as normas internacionais de auditoria, do IIA.

1998-2001

Operacional de TI

- Microinformática;
- Segurança Física;
- Segurança Lógica;
- Redes Locais.

2002-2003

Sistemas Informatizados

- Sistemas Informatizados de Departamentos;
- Administração do Centro de Serviço de Informática;
- Estrutura Normativa da Área de Informática.

2004-2005

Gestão de TI

- Administração da Infraestrutura de TI;
- Gerência e Desenvolvimento Organizacional de TI;
- Segurança da Informação;
- Administração de Banco de Dados;
- Administração de Sítios.

2006-2008

Áreas de conhecimento de TI

- Administração de Redes;
- Administração de Banco de Dados;
- Administração de Dados;
- Gestão de TI;
- Gestão do Ciclo de Vida de Sistemas de Informação;
- Gerência de Mudanças.

2009-2011

Governança de TI

Baseado em 31 Processos Genéricos de TI, do CobiT 4.1

- Viabilização da Governança de TI;
- Garantia da Segurança de Sistemas Informatizados;
- Gestão de Investimentos de TI;
- Identificação e Alocação de Custos de TI.

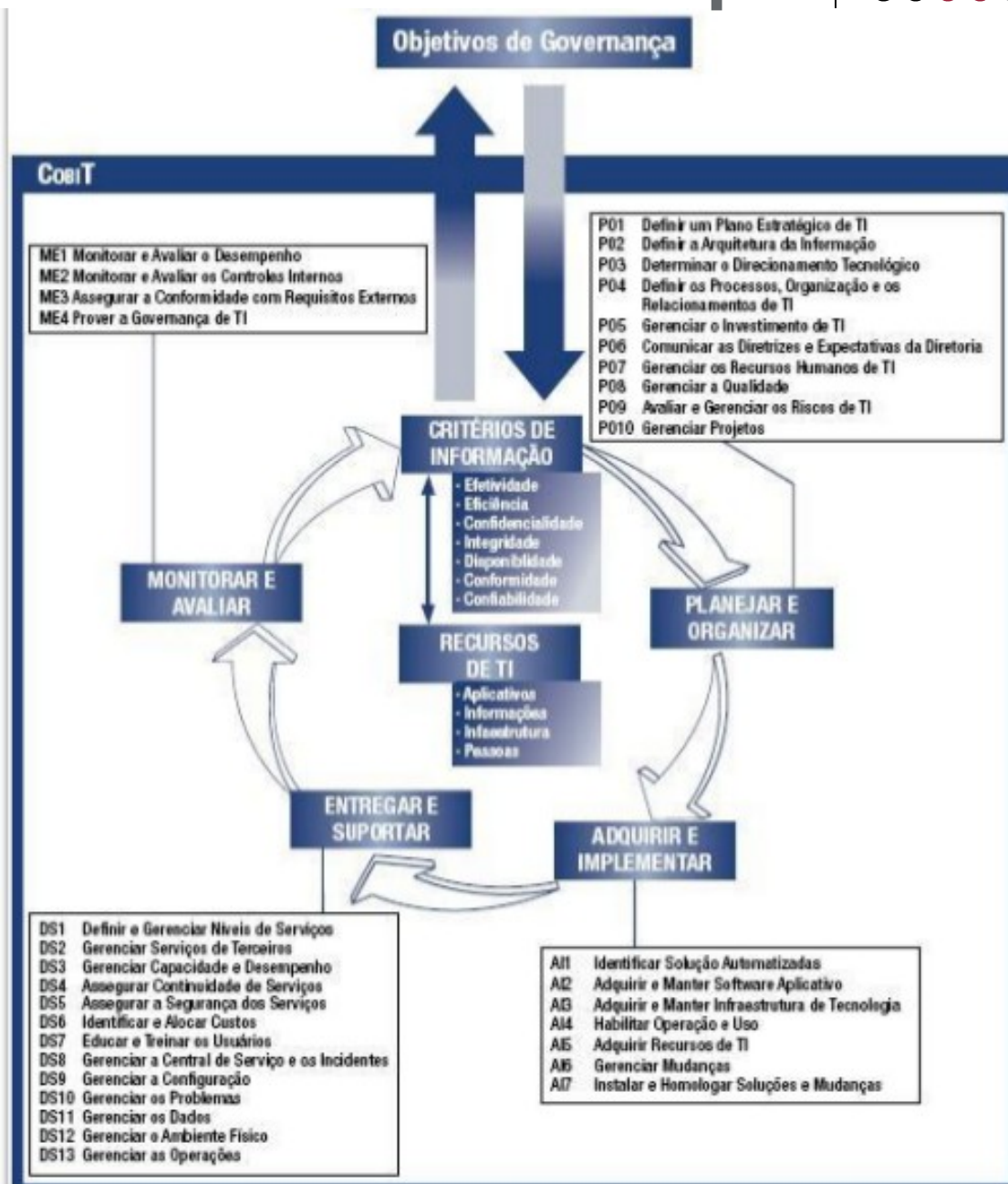


Uso do Cobit no Processo de Auditoria de TI

- A Auditoria Interna do Bacen, na evolução do processo de auditoria de TI, definiu o CobiT 4.1 como a referência básica para os trabalhos de auditoria interna
- No processo, o CobiT se destina principalmente na definição dos objetos e do escopo de auditorias e na **identificação dos objetivos, dos controles e dos riscos** de TI, relacionados com os objetos
- Controle é definido como políticas, procedimentos, práticas e estruturas organizacionais criadas para **prover uma razoável garantia de que os objetivos de negócios serão atingidos** e que eventos indesejáveis serão evitados ou detectados e corrigidos



Uso do Cobit no Processo de Auditoria de TI





Plano Anual de Atividades da Auditoria Interna

- O **Paint** é o planejamento das auditorias que serão realizadas durante um determinado exercício
- Encaminhado previamente à Controladoria Geral da União (CGU) para sugestões e aprovado pela Diretoria Colegiada
- A definição dos objetos a serem auditados no exercício está baseada em uma **matriz de risco**, que identifica o grau de importância do objeto para a organização (avaliação dos gestores dos objetos) e a compara com o grau de confiança da auditoria nos controles desses objetos



Plano Anual de Atividades da Auditoria Interna

Matriz de risco para elaboração do Paint

I m p o r t â n c i a d o P r o c e s s o	M u l t o A l t a					
	A l t a					
	M é d i a					
	B a i x a					
	M B u a i l i t x o a					
		Muito Alta	Alta	Média	Baixa	Muito Baixa
Confiabilidade no Controle Interno						



Plano Anual de Atividades da Auditoria Interna

- **Importância:** relacionamento do processo com o objetivo estratégico; impacto na reputação da instituição, em caso de incidentes; e materialidade dos recursos relacionados
- **Confiabilidade do controle:** quantidade de recomendações pendentes de solução; e o resultado da avaliação do controle interno de auditorias anteriores



Processo de Auditoria Interna de TI

• Planejamento da Auditoria:

- ✓ Realiza o levantamento das informações sobre o processo a ser avaliado;
- ✓ Utiliza como referência básica os preceitos do [CobiT 4.1](#);
- ✓ As informações levantadas são registradas em papéis de trabalhos específicos e padronizados.

• Execução da Auditoria:

- ✓ Inicia os trabalhos de campo, buscando as evidências que demonstrem a adequação ou a necessidade de melhoria de controle;
- ✓ As tarefas são definidas previamente, na fase de planejamento;
- ✓ Os pontos são apresentados de antemão aos representantes da unidade auditada.

• Relatório de Auditoria:

- ✓ Elabora o Relatório de Auditoria.
- ✓ A unidade auditada e/ou recomendada tem a oportunidade de apresentar sugestões e críticas sobre os resultados apresentados.

PLANEJAMENTO DA AUDITORIA

[QACI](#)

[NACI](#)

[MORC](#)

[PROCEDI-
MENTOS](#)

EXECUÇÃO DA AUDITORIA

[Aplicação dos
Procedimentos](#)

[Apresentação dos
Pontos de Auditoria](#)

RELATÓRIO DA AUDITORIA

[Elaboração da
Minuta do Relatório](#)

[Encaminhamento da
Minuta para
Avaliação](#)

[Encaminhamento
do Relatório às
partes interessadas](#)



Processo de Auditoria Interna de TI – Planejamento

- Elaboração do Questionário de Avaliação do Controle Interno (QACI)
 - O QACI é o conjunto de questões objetivas que visa auxiliar a equipe de auditoria na avaliação dos controles instituídos para mitigar os riscos inerentes ao processo auditado

Questão	Avaliação	Comentário
Questão de controle?	(1) Inexistente (2) Inicial/ <i>Ad hoc</i> (3) Repetível (4) Definido (5) Gerenciado (na) Não aplicável	Descrição do controle ou justificativa para a sua não aplicação.



Processo de Auditoria Interna de TI – Planejamento

- Elaboração do Questionário de Avaliação do Controle Interno (QACI)

Escala	Descrição
1 - Inexistente	Controle inexistente e os gestores reconhecem a necessidade do mesmo.
2 – Inicial/ <i>Ad hoc</i>	Controle desestruturado, sem padronização e gerido ao nível individual.
3 – Repetível	Controle padronizado localmente, no entanto, o treinamento e a comunicação não são formalizados.
4 – Definido	Controle padronizado para todo o processo, com documentação, treinamento e comunicação formais. Contudo, a probabilidade de detecção de desvios é baixa.
5 – Gerenciado	Controle institucionalizado, com ações detectivas e corretivas para não conformidades. Melhoria contínua, boas práticas e automação são utilizadas
na – Não aplicável	Controle Inexistente e os gestores não reconhecem a necessidade dos mesmos.



Processo de Auditoria Interna de TI – Planejamento

- Elaboração do Questionário de Avaliação do Controle Interno (QACI)
 - Deve ser respondido pela equipe de auditoria
 - Oportunidade para a unidade auditada entender, de forma detalhada, o objetivo da auditoria e oferecer informações que auxiliará na delimitação do escopo do trabalho
 - Ao final da aplicação do QACI, o auditor deverá concluir se o controle interno para a atividade sob exame é adequado e efetivo. O controle interno pode ser considerado: Ótimo, Bom, Regular, Deficiente ou Precário



Processo de Auditoria Interna de TI – Planejamento

- Elaboração do Mapa de Objetivos, Riscos e Controles (MORC)
 - **Objetivos:** resultados quantitativos e/ou qualitativos que o processo precisa alcançar
 - **Riscos:** evento ou condição incerta que, se ocorrer, terá um efeito positivo ou negativo sobre um objetivo
 - **Controles:** mitigam, evitam ou transferem os riscos inerentes aos objetivos do processo



Processo de Auditoria Interna de TI – Planejamento

- Elaboração do Mapa de Objetivos, Riscos e Controles (MORC)
 - É o papel de trabalho onde serão registrados os objetivos, os riscos e os controles do processo de TI em análise. Recebe informações do QACI, possibilita a priorização dos riscos inerentes ao processo e dá suporte à decisão sobre os objetivos e o escopo da auditoria



Processo de Auditoria Interna de TI – Planejamento

- Elaboração do Mapa de Objetivos, Riscos e Controles (MORC)

PROCESSO AUDITÁVEL: <Nome do Processo>										
Objetivo do Processo de TI		<Descrição do Objetivo do Processo>								
Código do Risco	Descrição do Risco	<u>Importância do risco</u>			Atividades de Controle	Avaliação do controle		<u>Impacto na Auditoria</u>		Ref.
		Impacto	Probabilidade	Resultado		Nível de Eficácia	Comentários	Hiato de controle (prioridade)	Indicação de procedimentos	



Processo de Auditoria Interna de TI – Planejamento

- Elaboração do Mapa de Objetivos, Riscos e Controles (MORC)
 - **Objetivo do processo de TI:** objetivos a serem alcançados pelo processo de TI, em análise, devem ser identificados e registrados pela equipe, em campo específico do MORC
 - **Descrição do risco:** riscos dos objetivos dos processos de TI não serem alcançados devem ser identificados, descritos e registrados pela equipe de auditoria. Para padronizar o nível de detalhamento da descrição dos riscos, convencionou-se que cada questão do QACI originará a uma descrição de risco



Processo de Auditoria Interna de TI – Planejamento

- Elaboração do Mapa de Objetivos, Riscos e Controles (MORC)

PROCESSO AUDITÁVEL: <Nome do Processo>										
Objetivo do Processo de TI		<Descrição do Objetivo do Processo>								
Código do Risco	Descrição do Risco	<u>Importância do risco</u>			Atividades de Controle	Avaliação do controle		<u>Impacto na Auditoria</u>		Ref.
		Impacto	Probabilidade	Resultado		Nível de Eficácia	Comentários	Hiato de controle (prioridade)	Indicação de procedimentos	



Processo de Auditoria Interna de TI – Planejamento

- Elaboração do Mapa de Objetivos, Riscos e Controles (MORC)
 - **Importância do Risco:** A equipe de auditoria deve avaliar os riscos identificados, com base na probabilidade e no impacto de sua concretização, utilizando parâmetros de 1 a 5, conforme o “**Quadro de distribuição de riscos da atividade**”
 - **Impacto** é a magnitude de um efeito negativo, no caso de o risco se materializar, ou seja, se um evento negativo efetivamente ocorrer
 - **Probabilidade** de o risco se materializar, considerando a ausência de uma ação administrativa no sentido de mitigá-lo



Processo de Auditoria Interna de TI – Planejamento

- Elaboração do Mapa de Objetivos, Riscos e Controles (MORC)
- QUADRO DE DISTRIBUIÇÃO DE RISCOS DA ATIVIDADE

QUADRO DE DISTRIBUIÇÃO DE RISCOS DA ATIVIDADE						
IMPACTO	Muito alto	Risco alto	Risco alto	Risco muito alto	Risco muito alto	Risco muito alto
	Alto	Risco médio	Risco médio	Risco alto	Risco alto	Risco muito alto
	Médio	Risco baixo	Risco médio	Risco médio	Risco alto	Risco alto
	Baixo	Risco muito baixo	Risco baixo	Risco baixo	Risco médio	Risco médio
	Nulo	Risco muito baixo	Risco muito baixo	Risco muito baixo	Risco muito baixo	Risco muito baixo
		Improvável	Baixa	Média	Alta	Muito alta
		PROBABILIDADE				



Processo de Auditoria Interna de TI – Planejamento

- Elaboração do Mapa de Objetivos, Riscos e Controles (MORC)

PROCESSO AUDITÁVEL: <Nome do Processo>										
Objetivo do Processo de TI		<Descrição do Objetivo do Processo>								
Código do Risco	Descrição do Risco	<u>Importância do risco</u>			Atividades de Controle	Avaliação do controle		<u>Impacto na Auditoria</u>		Ref.
		Impacto	Probabilidade	Resultado		Nível de Eficácia	Comentários	Hiato de controle (prioridade)	Indicação de procedimentos	



Processo de Auditoria Interna de TI – Planejamento

- Elaboração do Mapa de Objetivos, Riscos e Controles (MORC)
 - **Atividades de controle:** Os mecanismos de controle adotados pela administração para a mitigação de cada um dos riscos relacionados
 - **Avaliação do controle:** A equipe de auditoria deve registrar a sua avaliação preliminar sobre a efetividade da atividade de controle instituída em relação ao risco que pretende mitigar, incluindo-se a possibilidade de avaliar outros tipos de respostas ao risco. A avaliação deve indicar o nível de eficácia do controle, considerando a seguinte escala conceitual: (1) inexistente; (2) fraco; (3) insatisfatório; (4) satisfatório; e (5) forte



Processo de Auditoria Interna de TI – Planejamento

- Elaboração do Mapa de Objetivos, Riscos e Controles (MORC)

PROCESSO AUDITÁVEL: <Nome do Processo>										
Objetivo do Processo de TI		<Descrição do Objetivo do Processo>								
Código do Risco	Descrição do Risco	<u>Importância do risco</u>			Atividades de Controle	Avaliação do controle		<u>Impacto na Auditoria</u>		Ref.
		Impacto	Probabilidade	Resultado		Nível de Eficácia	Comentários	Hiato de controle (prioridade)	Indicação de procedimentos	



Processo de Auditoria Interna de TI – Planejamento

- Elaboração do Mapa de Objetivos, Riscos e Controles (MORC)
 - **Impacto na auditoria:** Um primeiro indicador do tratamento que o mapeamento e a avaliação dos riscos e dos controles merecerão na seqüência dos trabalhos de auditoria
 - É apurado a partir da combinação da “**importância do risco**” com o nível de “**eficácia do controle**”, conforme o “**Quadro de hiato de controle**”



Processo de Auditoria Interna de TI – Planejamento

- Elaboração do Mapa de Objetivos, Riscos e Controles (MORC)
-
- QUADRO DE HIATO DE CONTROLE

QUADRO DE HIATO DE CONTROLE						
RISCO	Muito alto	Prioridade alta	Prioridade alta	Prioridade muito alta	Prioridade muito alta	Prioridade muito alta
	Alto	Prioridade média	Prioridade média	Prioridade alta	Prioridade alta	Prioridade muito alta
	Médio	Prioridade baixa	Prioridade média	Prioridade média	Prioridade alta	Prioridade alta
	Baixo	Prioridade muito baixa	Prioridade baixa	Prioridade baixa	Prioridade média	Prioridade média
	Muito baixo	Prioridade muito baixa	Prioridade muito baixa	Prioridade muito baixa	Prioridade muito baixa	Prioridade muito baixa
		Forte	Satisfatório	Insatisfatório	Fraco	Inexistente
		CONTROLE				



Processo de Auditoria Interna de TI – Planejamento

- Elaboração do Mapa de Objetivos, Riscos e Controles (MORC)

PROCESSO AUDITÁVEL: <Nome do Processo>										
Objetivo do Processo de TI		<Descrição do Objetivo do Processo>								
Código do Risco	Descrição do Risco	<u>Importância do risco</u>			Atividades de Controle	Avaliação do controle		<u>Impacto na Auditoria</u>		Ref.
		Impacto	Probabilidade	Resultado		Nível de Eficácia	Comentários	Hiato de controle (prioridade)	Indicação de procedimentos	



Processo de Auditoria Interna de TI – Planejamento

- Elaboração do Mapa de Objetivos, Riscos e Controles (MORC)
 - **Referência:** Indicação do número do procedimento de execução de auditoria, incorporado no sistema informatizado de suporte das atividades da auditoria, importante para permitir a supervisão dos trabalhos desenvolvidos



Processo de Auditoria Interna de TI – Planejamento

- Elaboração dos procedimentos de auditoria
 - Para viabilizar a supervisão efetiva na fase de execução, foi padronizada a descrição do procedimento de auditoria que será executado
 - A equipe deve estruturar as informações da seguinte forma:
 - (1) Número e Título do Procedimento
 - (2) Risco avaliado
 - (2) Objetivo do procedimento
 - (3) Questão a ser respondida pela equipe de auditoria
 - (4) Objetos de teste
 - (5) Descrição do teste



Processo de Auditoria Interna de TI – Execução

- Aplicação do Programa de Auditoria
 - Aplicação os procedimentos de auditoria:
 - Solicita os objetos de análise ao auditado
 - Realiza os testes previstos
 - Responde as questões definidas
 - Identifica e registra as evidências de auditoria
 - Identifica e registra as possíveis recomendações





Processo de Auditoria Interna de TI – Execução

- Realização de uma reunião com o auditado para tratar dos achados da auditoria
 - Informa ao auditado o resultado do trabalho de auditoria de TI, apresentando os **pontos fortes e fracos** identificados
 - Indica os pontos que serão abordados no relatório, apresentando as evidências obtidas





Processo de Auditoria Interna de TI – Relatório

Elaboração da Minuta do Relatório

- O relatório tem um padrão e utiliza informações produzidas no planejamento e na execução da auditoria:
 - ✓ Preâmbulo do relatório;
 - ✓ Objetivos da auditoria;
 - ✓ Escopo do trabalho da auditoria;
 - ✓ Estrutura do controle interno existente para o processo auditável;
 - ✓ Conclusão sobre o controle interno e o trabalho de auditoria;
 - ✓ Assunto: *Número e Título do Assunto*;
 - ✓ Evidência identificada: *Critério; Condição; Causa; e Consequência*;
 - ✓ Recomendação;
 - ✓ Prazos acordados com a unidade recomendada para o atendimento das recomendações ou a apresentação do plano de ação.





Processo de Auditoria Interna de TI – Relatório

Encaminhamento da Minuta do Relatório da Auditoria para Avaliação

- A minuta do relatório da auditoria é encaminhada à unidade auditada para avaliação e apresentação de prazos;
- A unidade pode apresentar sugestões e críticas, que podem ser oferecidas por escrito ou em reuniões específicas;
- Cabe à equipe de auditoria buscar a melhor solução para os possíveis questionamentos apresentados, observando os princípios éticos que norteiam a profissão de auditor.





Conclusões

- Executar auditoria interna, baseada em **processos** formalizados e impessoais, elevou a confiança e a qualidade dos resultados dos trabalhos da auditoria interna de TI
- O processo de implantação de um modelo de governança de TI exige esforço, atenção e investimento, o que cria, na maioria das vezes, resistência da administração e das pessoas envolvidas
- A visão dos risco é ampliada, mas os **gestores de TI da organização necessitam de tempo** para compreender, organizar e estabelecer os controles que mitiguem esses riscos



Conclusões

- A compreensão pelas áreas e negócios sobre governança de TI deve evoluir, para que forneçam à área de TI os insumos necessários para o adequado funcionamento de seus processos
- Os **gestores tem dificuldades para visualizar os benefícios** e o valor que a governança de TI pode agregar aos negócios, além de as pessoas envolvidas considerarem o controle interno oneroso para as suas rotinas
- A auditoria deve definir estratégias para viabilizar a governança de TI na organização

Bibliografia



- Imoniana J. O. Auditoria de Sistemas de Informação. 2a edição. Editora Atlas.
- Nardon, Nasi Auditores e Consultores. Cobit 4.01 – Objetivos de controle para informação e tecnologias relacionadas.
<http://www.nardonnasi.com.br/>. Acessado em Janeiro/2014.
- Patrocínio C. L. GOVERNANÇA DE TI: Um desafio para a Auditoria Interna
www.iiabrazil.org.br/.../PDFs.../Apresentacao_Conbrai2009_Cosme.pdf
Acessado em Janeiro/2014.

